

Manual del Sistema de Gestión de Seguridad de la Información (SGSI)

Organización: TechSolutions

Estándar de Referencia: ISO/IEC 27001:2022

Autor: Damian R. Mejía

Año: 2026

ÍNDICE GENERAL

- **Capítulo I: Introducción y Objetivos**
 - 1.1 Contexto y Justificación
 - 1.2 Objetivos del SGSI (General y Específicos)
 - 1.3 Correspondencia con la Familia ISO 27000
- **Capítulo II: Contexto de la Organización y Alcance (Cláusula 4)**
 - 2.1 Comprensión de la Organización
 - 2.2 Determinación del Alcance y Límites Físicos
 - 2.3 Límites Virtuales y Lógicos
- **Capítulo III: Liderazgo y Partes Interesadas (Cláusula 5)**
 - 3.1 Compromiso de la Dirección
 - 3.2 Matriz de Roles y Responsabilidades de las Partes Interesadas
- **Capítulo IV: Planificación y Gestión de Riesgos (Cláusula 6)**
 - 4.1 Inventario de Activos de Información (Hardware, Software y Datos)
 - 4.2 Identificación de Amenazas y Vulnerabilidades
 - 4.3 Apreciación y Priorización de Riesgos
- **Capítulo V: Soporte y Operación (Cláusulas 7 y 8)**
 - 5.1 Recursos e Infraestructura de Soporte
 - 5.2 Concienciación y Información Documentada
 - 5.3 Planificación y Control Operacional
- **Capítulo VI: Declaración de Aplicabilidad (Anexo A - Controles)**
 - 6.1 Controles Organizacionales y de Personas
 - 6.2 Controles Físicos
 - 6.3 Controles Tecnológicos
- **Capítulo VII: Evaluación del Desempeño y Mejora (Cláusulas 9 y 10)**
 - 7.1 Seguimiento, Auditoría Interna y Revisión
 - 7.2 Acciones Correctivas y Mejora Continua
- **Capítulo VIII: Marcos Complementarios de Ciberseguridad y Gobierno**
 - 8.1 Integración con SOC 2 (Criterios de Servicios de Confianza)
 - 8.2 Alineación con NIST Cybersecurity Framework (CSF)
 - 8.3 Gestión de Servicios de TI bajo ITIL v4
 - 8.4 Gobierno Corporativo de TI mediante COBIT

Capítulo I: Introducción y Objetivos

1.1 Contexto y Justificación

Los activos más importantes de TechSolutions son la información y la integridad de sus datos. Dado que el entorno de negocio actual traslada gran parte de su infraestructura a ecosistemas digitales, resulta crítico evaluar qué vectores pueden estar expuestos para fines maliciosos. La implementación de un SGSI bajo la norma ISO/IEC 27001 exige evaluar los controles y procesos en cada área organizativa, estableciendo una base sólida para optar por la certificación por primera vez y asegurar su mantenimiento continuo frente a futuras actualizaciones.

1.2 Objetivos del SGSI

- **Objetivo General:** Prevenir riesgos de seguridad de la información en TechSolutions mediante un estudio analítico previo a la adopción de ISO/IEC 27001, minimizando el costo de mantenimiento posterior.
- **Objetivos Específicos:**
 - Mapear vulnerabilidades físicas y lógicas de la infraestructura corporativa.
 - Priorizar la protección de activos de criticidad alta ante vectores de amenaza.
 - Establecer protocolos de respuesta ante incidentes y escenarios de riesgo.
 - Diseñar planes de capacitación y concientización en ciberseguridad para el personal.

1.3 Correspondencia con la Familia ISO 27000

Este manual se alinea metodológicamente con la serie ISO 27000:

- **ISO 27000:** Aporta el vocabulario fundamental y las definiciones de referencia.
- **ISO 27001:** Define los requisitos auditables para el SGSI.
- **ISO 27002:** Guía la implementación de los 93 controles de seguridad distribuidos en dominios organizacionales, humanos, físicos y tecnológicos.
- **ISO 27005:** Proporciona las directrices aplicadas para la gestión y apreciación del riesgo en TechSolutions.

Capítulo II: Contexto de la Organización y Alcance (Cláusula 4)

2.1 Comprensión de la Organización

TechSolutions opera en un entorno de alta demanda tecnológica que requiere asegurar la confidencialidad, integridad y disponibilidad de sus datos. Las prioridades del SGSI se estructuran a partir de sus dos sucursales físicas (San José y Cartago) y sus plataformas de servicios web y cloud.

2.2 Determinación del Alcance y Límites Físicos

El perímetro físico auditado bajo este SGSI comprende:

- **Sucursal San José (Oficina Central):** Incorpora la oficina de directores, la Mesa de Servicio técnico de TI, el cuarto de comunicaciones/redes, el servidor central y la tienda comercial con bodega de acceso restringido al público.
- **Sucursal Cartago:** Incorpora la infraestructura de atención comercial, cajas y redes locales asociadas.

Áreas de Acceso Restringido Físico:

- **Cuarto de Redes y Servidor Central:** Acceso limitado estrictamente al personal técnico autorizado y directores de IT.
- **Bodega de Productos:** Acceso exclusivo a agentes de ventas y técnicos acreditados.
- **Oficinas Ejecutivas:** Ingreso exclusivo para directores corporativos.

2.3 Límites Virtuales y Lógicos

El alcance lógico comprende los siguientes entornos e interconexiones de datos:

- **Segmentación por Redes VLAN:** Aislamiento perimetral para evitar que el tráfico de datos o incidentes de un entorno afecten las operaciones generales.
- **Entorno de Tienda y Cajas:** Permite consultas restringidas a las bases de datos de catálogo, clientes y stock en línea.
- **Entorno de Mesa de Servicio:** Acceso a datos de clientes y catálogo. Integración con el sistema cloud de Atlassian para la gestión de tickets de soporte y reparaciones.
- **Entorno de Dirección y Operaciones:** Acceso centralizado y total a las 3 bases de datos del negocio (Clientes, Productos, Ventas).

- **Plataformas Públicas:** Sitio web corporativo expuesto a internet que faculta a los clientes a registrarse, gestionar productos y levantar tickets técnicos.
- **Entorno Cloud Corporativo:** Módulos en la nube para reportes financieros, control automatizado de stock y analítica de ventas.

Capítulo III: Liderazgo y Partes Interesadas (Cláusula 5)

3.1 Compromiso de la Dirección

La alta gerencia de TechSolutions asume una participación activa en la gobernanza del SGSI, garantizando la asignación de recursos financieros, tecnológicos y humanos esenciales para el mantenimiento de la postura de seguridad.

3.2 Matriz de Roles y Responsabilidades

Rol de la Organización	Responsabilidades Específicas del SGSI	Permisos de Datos Asociados
Dirección y Operaciones	Mantener control administrativo de activos, contratos con proveedoras y planillas corporativas.	Acceso total de lectura/escritura a las 3 Bases de Datos core.
Agentes de TI y Redes	Mantenimiento preventivo y correctivo de endpoints, servidores, firewalls, routers, web corporativa y CCTV.	Administración de infraestructura, logs y redes VLAN.
Agentes de Ventas y Servicio	Interacción con clientes en tiendas, ingreso diario de información de ventas y actualización automática de stocks.	Captura de datos inicial; prohibida la edición o alteración directa de bases de datos.

Capítulo IV: Planificación y Gestión de Riesgos (Cláusula 6)

4.1 Inventario de Activos de Información

- **Hardware Crítico:** 10 computadoras de escritorio (Críticidad: Alto), 10 laptops corporativas (Críticidad: Medio), 1 Servidor Central Linux (Críticidad: Alto), 6 módems/routers, 8 datáfonos de cobro (Críticidad: Alto), 10 escáneres de código de barras (Críticidad: Alto), 2 Firewalls locales, 4 UPS y 2 Plantas de emergencia eléctrica (Autonomía de 1 hora ante cortes).
- **Software Operativo:** Estaciones de trabajo basadas en Windows, Servidor de Producción en Linux, Antivirus Kaspersky de gestión unificada y plataforma web local.
- **Datos de Negocio (Críticidad: Alto):** Bases de datos de Clientes, Productos y Ventas; registros financieros de planillas; base de datos de tickets técnicos y registros de usuarios en línea.

4.2 Identificación de Amenazas y Vulnerabilidades

- **Amenazas Ambientales/Físicas:** Alta actividad sísmica en la región; tormentas eléctricas concurrentes que desencadenan fallos y apagones en la red eléctrica comercial; riesgo latente de asaltos físicos a los locales comerciales o robo de inventarios.
- **Amenazas Digitales e Internas:** Ataques de denegación de servicio o intrusión en la página web pública; malware introducido por usuarios de la red interna; exfiltración de credenciales corporativas y robo/venta de activos digitales en la Deep Web perpetrado por actores internos maliciosos.
- **Vulnerabilidades:** Empleo de contraseñas débiles o falta de rotación en routers y equipos de usuario; ausencia de doble factor de autenticación (MFA) para saltar validaciones sencillas; falta de cifrado en la transmisión de información sensible; estaciones con sistemas desactualizados y brechas de conocimiento en ciberseguridad del personal operativo.

4.3 Apreciación y Priorización de Riesgos

Escenario de Riesgo	Probabilidad	Impacto Estimado	Prioridad ISO 27001
Intrusión exógena a Bases de Datos Core	Alta	Pérdida financiera y daño reputacional	Alta (Acción Inmediata)
Fuga de datos por Mal Actor Interno	Media	Compromiso legal y de propiedad digital	Alta (Acción Inmediata)
Acceso no autorizado a áreas restringidas	Media	Daño o alteración física de servidores	Alta (Acción Inmediata)
Fallo en Suministro Eléctrico por Tormentas	Alta	Interrupción de ventas y operaciones de TI	Alta (Acción Inmediata)
Infección de estaciones de trabajo por Malware	Alta	Cifrado de archivos e indisponibilidad local	Media (Mitigación)
Vulneración/Defacement de la Página Web	Media	Pérdida de canales transaccionales en línea	Media (Mitigación)
Uso de Dispositivos o Routers Desactualizados	Alta	Explotación de brechas de seguridad conocidas	Media (Atención)

Capítulo V: Soporte y Operación (Cláusulas 7 y 8)

5.1 Recursos e Infraestructura de Soporte

TechSolutions destina soporte técnico enfocado en la competencia de su personal y la resiliencia física de su infraestructura (uso de UPS y plantas automatizadas) para garantizar el entorno operativo del SGSI.

5.2 Concienciación y Información Documentada

- **Concienciación:** Se establece un programa de entrenamiento obligatorio en seguridad para el personal operativo (contadores, secretarias, técnicos y agentes de servicio) enfocado en identificar phishing, uso correcto de contraseñas y reporte de anomalías.
- **Información Documentada:** Toda política, registro de cambios en redes VLAN y bitácoras de acceso al cuarto de servidores deben mantenerse archivados, controlados y con versiones protegidas contra modificaciones no autorizadas.

5.3 Planificación y Control Operacional

TechSolutions planifica sus ventanas de mantenimiento técnico y auditorías informáticas de forma programada para verificar que los límites lógicos y perimetrales definidos operen bajo los umbrales de riesgo aceptados por la dirección.

Capítulo VI: Declaración de Aplicabilidad (Anexo A - Controles)

Derivado del análisis de la ISO/IEC 27002, TechSolutions formaliza la adopción de los siguientes controles indispensables:

6.1 Controles Organizacionales y de Personas

- **Política de Credenciales Robustas:** Prohibición estricta de contraseñas por defecto en routers corporativos y estaciones Windows. Requisito obligatorio de complejidad (mínimo 12 caracteres, caracteres especiales) y despliegue forzoso de Autenticación Multifactor (MFA) para accesos a bases de datos y nubes.
- **Seguridad en el Empleo:** Firmas obligatorias de acuerdos de confidencialidad (NDA) para todo el personal y revocación inmediata de privilegios lógicos al cesar funciones para mitigar la amenaza de actores internos.

6.2 Controles Físicos

- **Aislamiento Perimetral Crítico:** Instalación de control de acceso electrónico/biométrico en el cuarto de servidores de San José.
- **Monitoreo Físico Continuo:** Vigilancia continua mediante las cámaras de circuito cerrado (CCTV) sobre las áreas de bodega, talleres de TI y piso de tienda en ambas sucursales.
- **Protección ante Fallos de Energía:** Plan de mantenimiento preventivo mensual sobre las plantas eléctricas y las 4 UPS corporativas para garantizar la continuidad ininterrumpida de al menos 1 hora de operación durante tormentas eléctricas.

6.3 Controles Tecnológicos

- **Seguridad de Red y Canales:** Configuración de reglas restrictivas en los 2 firewalls locales. Aislamiento e inspección estricta del tráfico entre las diferentes redes VLAN lógicas para asegurar que las conexiones públicas de la web externa estén completamente segregadas de la red interna de administración.
- **Protección contra Código Malicioso:** Escaneos automatizados diarios a través de la consola centralizada del Antivirus Kaspersky en todos los endpoints de la empresa.
- **Cifrado de Datos:** Cifrado obligatorio de canales de comunicación sensibles (implementación de certificados SSL/TLS HTTPS en la web) y bases de datos en reposo.

- **Gestión de Parches:** Ciclo mensual de actualización automatizada para parches de seguridad de Windows y actualizaciones críticas de seguridad del servidor Linux central.
- **Copias de Seguridad (Backups):** Generación diaria automatizada de respaldos de las bases de datos de Clientes, Productos y Ventas, almacenados de manera cifrada e independiente a la red de producción.

Capítulo VII: Evaluación del Desempeño y Mejora (Cláusulas 9 y 10)

7.1 Seguimiento, Auditoría Interna y Revisión

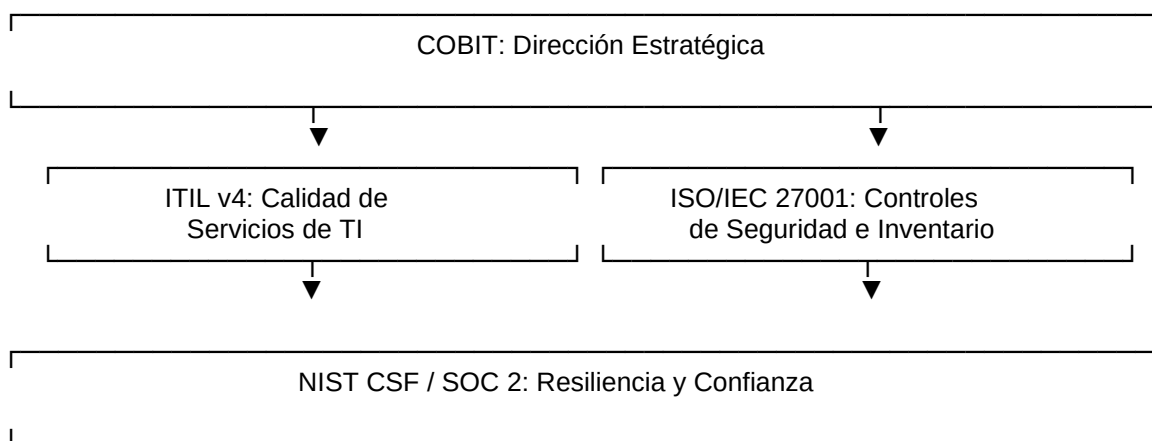
- **Métricas de Desempeño:** Monitoreo mensual de intentos de inicio de sesión fallidos, alertas de malware contenidas por Kaspersky y disponibilidad de la página web corporativa.
- **Auditorías Internas:** Revisiones semestrales conducidas por el equipo de TI o consultores externos independientes para comprobar la correcta aplicación de los controles del Anexo A.
- **Revisión por la Dirección:** Sesión anual donde la junta directiva evalúa el estado del SGSI, analiza las acciones correctivas pendientes y aprueba el presupuesto de ciberseguridad.

7.2 Acciones Correctivas y Mejora Continua

Ante cualquier desviación (ej. detección de un router desactualizado o una contraseña débil), se abrirá un registro de No Conformidad, asignando un técnico de TI para ejecutar la acción correctiva de inmediato y documentar las lecciones aprendidas para nutrir el ciclo de mejora continua.

Capítulo VIII: Marcos Complementarios de Ciberseguridad y Gobierno

Para potenciar el SGSI de TechSolutions, la organización adopta y fusiona de forma sinérgica las directrices de cuatro estándares globales de la industria:



8.1 Integración con SOC 2 (Criterios de Servicios de Confianza)

Dado que TechSolutions interactúa con datos transaccionales y permite a clientes externos gestionar tickets en la nube (vía Atlassian), se adopta el marco **SOC 2** como un estándar complementario ideal para empresas SaaS y de servicios tecnológicos.

- **Criterios Evaluados:** SOC 2 aporta informes independientes externos sobre el cumplimiento de los cinco Criterios de Servicios de Confianza: seguridad, disponibilidad, integridad del procesamiento, confidencialidad y privacidad.
- **Controles Compartidos:** Se unifica la gobernanza para que los mismos procedimientos del SGSI satisfagan ambos marcos en: planes de gestión de incidentes, controles de acceso robustos, seguridad física de los locales, gestión de cambios lógicos, gestión de proveedores y copias de seguridad de los datos core.

8.2 Alineación con NIST Cybersecurity Framework (CSF)

TechSolutions combina la robusta estructura formal y auditable de ISO 27001 con la agilidad, flexibilidad y enfoque práctico basado en riesgos que provee el marco voluntario del **NIST CSF**.

- **Postura de Seguridad Sólida:** La adopción conjunta permite mapear las actividades de los agentes de TI y de redes en base a las funciones del NIST (Identificar, Proteger, Detectar, Responder y Recuperar).

- **Confianza del Cliente:** Esta combinación genera una postura de seguridad transparente y altamente confiable frente a socios comerciales externos y clientes de soporte de hardware.

8.3 Gestión de Servicios de TI bajo ITIL v4

Mientras ISO 27001 define el *qué proteger*, el marco de referencia **ITIL** provee las mejores prácticas mundiales de *Service Management* para guiar el *cómo operar* los servicios informáticos con calidad.

- **Sistema de Valor del Servicio (SVS):** Bajo ITIL v4, TechSolutions estructura los servicios de su Mesa de Servicio y taller de reparaciones lógicas rompiendo viejos paradigmas e integrando la seguridad de la información de manera transversal en los objetivos, flujos, entradas y salidas de cada actividad técnica.

8.4 Gobierno Corporativo de TI mediante COBIT

Para asegurar que las inversiones de seguridad conversen con los objetivos financieros y estratégicos del negocio, se acopla el marco **COBIT** (administrado por ISACA).

- **Alineación Estratégica:** La integración de COBIT con ISO 27001 proporciona controles implementables sobre la tecnología de la información que aseguran la rendición de cuentas, la transparencia y el ajuste normativo de acuerdo a la cultura de TechSolutions.
- **Visión de Negocio:** Permite a los directores de departamento y TI identificar y gestionar proactivamente los riesgos tecnológicos de las sucursales, vinculando cada control de ciberseguridad con la generación de valor comercial y una dirección estratégica transparente.